

Care Access Navigator - Day 2

Project Objectives, Scope & Initial Requirements

HealthLine Regional Medical Center

IAM + GRC Healthcare Cybersecurity Capstone | Week 1: Planning

Organization	HealthLine Regional Medical Center (HRMC)	Day 2 Focus	Objectives, Scope & Requirements
Environment	Simulated / Non-Production	Data Rule	Synthetic Data Only

1. Day 2 Objective

Objective: Turn the Day 1 hospital scenario into a clear project plan by defining what the Care Access Navigator project is expected to achieve, what is included, what is excluded, the assumptions we are working under, and the first set of high-level requirements.

Why this matters for an IAM/GRC beginner: IAM (Identity and Access Management) focuses on who a user is, what access they need, and when that access should change or be removed. GRC (Governance, Risk and Compliance) focuses on risks, controls, evidence, and whether security requirements are being followed. Day 1 explained the environment; Day 2 begins the analyst mindset: define the goal, set boundaries, and write requirements before configuring technology. This helps prevent scope creep and gives later IAM and GRC work a clear direction.

2. How Day 2 Builds on Day 1

Day 1 established the basic HRMC environment: hospital departments, seven user populations, four applications, the IAM business problem, and the simulated ePHI boundary. **ePHI** means electronic Protected Health Information; in this project, it is fictional patient-related data used only for training. Day 2 does not redesign those items. Instead, it converts them into project-level objectives, scope rules, assumptions, and requirements.

Day 1 Established	Day 2 Adds
HRMC healthcare scenario	Project objectives
Users and applications	Project-wide in-scope / out-of-scope boundaries
Business problem	Project assumptions and constraints
Simulated ePHI boundary	Initial business, IAM, security, and GRC requirements

3. Project Objectives

The project objectives describe what the full 12-week capstone should demonstrate. Day 2 only documents these objectives; implementation happens in later weeks.

Objective 1 - Role-Based Access: Demonstrate that HRMC users receive access based on their job responsibilities. RBAC (Role-Based Access Control) assigns permissions through job roles, while least privilege means giving a user only the minimum access needed to do the job.

Objective 2 - Identity Lifecycle: Demonstrate how access is created, changed, and removed through Joiner-Mover-Leaver (JML) scenarios. JML represents the three common workforce events: a person joins, changes role or department, or leaves the organization.

Objective 3 - Access Governance: Demonstrate a process for requesting, approving, reviewing, and removing access. A periodic access review checks whether existing access is still appropriate and helps identify excessive, stale, mismatched, privileged, or expired access.

Objective 4 - Security Monitoring: Generate safe simulated authentication and access events and show how suspicious identity or ePHI-related activity can be detected and investigated. A SIEM (Security Information and Event Management) tool, such as Microsoft Sentinel, can collect and analyze security logs for this purpose.

Objective 5 - GRC Evidence: Connect IAM and security activities to risks, controls, evidence, gaps, exceptions, and remediation. In simple terms, a risk is what could go wrong, a control reduces that risk, evidence shows the control worked, and remediation is the corrective action taken when a gap is found.

Objective 6 - Management Reporting: Present useful IAM, security, risk, control, access-review, and remediation metrics through a simple management report or Tableau dashboard. Tableau is the reporting and visualization tool planned for presenting the project's results.

4. Project-Wide Scope

Scope answers a simple question: What are we actually building and demonstrating during this capstone? The purpose is to keep the project realistic and achievable.

In Scope for the 12-Week Project	Out of Scope
• Synthetic workforce identities for the 7 HRMC roles	• Real patient data, real ePHI, or production healthcare systems
• Keycloak IAM lab and Entra ID concepts where practical	• Full production EHR, patient portal, billing, or HR application development
• Four simulated/lightweight HRMC applications	• Full enterprise Entra ID, Privileged Access Management (PAM), Identity Governance and Administration (IGA), or SIEM deployment
• RBAC and least-privilege design	• Production integrations with a real hospital
• JML, access-request/approval, privileged/vendor access scenarios	• Real payment/insurance processing
• Periodic access review	• Formal HIPAA or NIST certification
• Authentication/access logs and at least 3 useful monitoring use cases	• Enterprise-scale penetration testing
• One end-to-end simulated access incident	• Large-scale user population or hundreds of lab accounts
• Risk register, control matrix, evidence index, gap/exception/remediation tracking	• Advanced self-service access portal or enterprise automation
• Tableau or simple management reporting	• Any use of unsanitized patient-level information in portfolio/GitHub material
• Sanitized documentation, screenshots, test evidence, and diagrams	

5. Project Assumptions & Constraints

- HRMC is a fictional organization created only for the capstone.
- All workforce identities, patients, logs, incidents, and evidence are synthetic or sanitized.
- Keycloak is the primary IAM lab. It is an identity platform used to create users, groups, roles, and authentication rules. Microsoft Entra ID, Microsoft's cloud identity service, is documented conceptually or demonstrated only where feasible.
- HRMC applications may be mock interfaces, lightweight applications, or sample datasets rather than full enterprise systems.
- Microsoft Sentinel may be used if feasible. Sentinel is a SIEM tool that helps collect and review security events; otherwise an equivalent lightweight log-analysis approach is acceptable.
- Excel/CSV can be used for data analysis and evidence, Tableau for dashboards and final reporting, Monday.com for project and GRC task/evidence tracking, and Lucidchart for architecture and workflow diagrams.
- The project must stay achievable within 12 weeks and should demonstrate analyst workflows rather than recreate a production hospital.
- Real patient information and production healthcare data are prohibited.

6. Initial High-Level Requirements

Requirements describe what the environment must be able to demonstrate later. These are intentionally high level on Day 2; detailed permissions and technical configuration are future work.

Area	Initial Requirement	Beginner Analyst Question
Business	Each user should have access that matches the responsibilities of their HRMC role.	Does this person need this access to do the job?

IAM	The environment must support users, groups, roles, account status, and role-based access assignments.	Who is the user and what role should they have?
Lifecycle	The project must demonstrate joiner, mover, and leaver access changes.	When should access be added, changed, or removed?
Approval	Selected access requests should include business justification and manager/owner approval.	Who approved the access and why?
Vendor / Privileged	Temporary or elevated access should be restricted, justified, and time-limited.	Does high-risk access have an owner and an end date?
ePHI	Only approved roles should access the synthetic patient information required for their scenario.	Is patient-related access appropriate and least privileged?
Logging	Authentication and access activity should create enough evidence for review and investigation.	Can we see what happened and who did it?
Monitoring	The project should support at least three useful identity/access detection use cases.	What activity should trigger analyst attention?
GRC	Risks, controls, evidence, exceptions, and remediation actions should be traceable.	What risk exists, what control addresses it, and what proves it worked?
Reporting	The project should produce understandable management metrics without exposing unnecessary patient-level detail.	Can a manager understand the security posture from the report?

7. Day 2 Requirement Priorities

To keep the work manageable, classify the initial requirements into three simple priorities. This is not a formal enterprise requirements exercise; it is a beginner-friendly way to decide what must be demonstrated first.

Priority	Meaning	Examples
Must Have	Needed for the core capstone to work	Synthetic data only, users/roles, RBAC, JML, access review, logging/evidence
Should Have	Strongly improves the demonstration	Access-request approval, vendor/privileged scenario, monitoring use cases, risk/control tracking
Could Have	Useful if time allows	Deeper Entra ID demonstration, extra automation, additional dashboards or incident scenarios

8. IAM / GRC Analyst View

IAM Analyst Focus	GRC Analyst Focus
Who should have access? What role should provide it? Who approves it? When should it change? When should it be removed? What evidence shows the IAM action occurred?	What risk does inappropriate access create? What control should reduce the risk? Who owns the control? What evidence proves the control operated? What gap or exception remains? What remediation is needed?

9. Quick Reference - Key Terms and Tools

These are the main terms used across Day 1 and Day 2. The definitions are intentionally simple so the document remains easy to follow.

Term / Tool	Simple Meaning in This Project
-------------	--------------------------------

IAM	Identity and Access Management - making sure the correct users receive the correct access.
GRC	Governance, Risk and Compliance - identifying risks, defining controls, keeping evidence, and tracking gaps or corrective actions.
RBAC / Least Privilege	RBAC gives access through job roles; least privilege limits that access to only what the user needs.
ePHI	Electronic Protected Health Information - simulated patient-related data in this lab; no real patient data is used.
JML	Joiner-Mover-Leaver - adding access when someone joins, changing it when their role changes, and removing it when they leave.
Access Review	A periodic check to confirm that a user's current access is still needed and appropriate.
Keycloak / Entra ID	Identity platforms used to manage users, groups, roles, and authentication; Keycloak is the primary lab platform.
SIEM / Microsoft Sentinel	Security log monitoring technology used to collect events and help analysts identify suspicious activity.
Risk / Control / Evidence / Remediation	Risk = what could go wrong; control = protection used to reduce the risk; evidence = proof the control worked; remediation = action taken to fix a gap.
Tableau / Monday.com / Lucidchart	Tableau supports reporting, Monday.com tracks project/GRC work and evidence, and Lucidchart is used for architecture and workflow diagrams.
HIPAA / NIST	Healthcare security/compliance concepts and cybersecurity frameworks that will be used later for control mapping, not formal certification.

Beginner tip: You do not need to memorize every term now. The goal is to recognize what each term means when it appears in an IAM or GRC workflow.

10. Day 2 Deliverables & Definition of Done

Day 2 is documentation and planning only. No Keycloak configuration or detailed RBAC implementation is required today.

Deliverable	What to Complete	Output	Done When
Project Objectives	Document 5-6 project outcomes	Objective section	A reader can explain what the project will demonstrate
Project Scope	Define project-wide in-scope and out-of-scope items	Scope table	The 12-week boundary is clear
Assumptions & Constraints	Record lab, data, tool, and schedule assumptions	Assumption list	No hidden expectations remain
Initial Requirements	Document business/IAM/security/GRC requirements	Requirement table	Future configuration has a clear purpose
Priority Review	Classify requirements as Must/Should/Could	Priority summary	Core MVP requirements are obvious